MINDFULAI LABS

Artificial Intelligence | 200 Employees | Toronto | Healthcare & Finance AI

AI Governance & ISO 42001 Implementation

Bias Testing | Explainability | Human Oversight | EU AI Act Compliance

ISO 42001 | NIST AI RMF | EU AI Act

Document:	AI Governance & ISO 42001 Implementation Plan
Company:	MindfulAI Labs (200 employees, healthcare & financial AI)
AI Systems:	Healthcare diagnostics (45 hospitals) + Financial risk scoring (20 institutions)
Regulation:	EU AI Act (High-Risk), Canada AIDA, GDPR, PIPEDA, EU MDR
Frameworks:	ISO/IEC 42001:2023, NIST AI RMF 1.0
Role:	AI Governance Lead
Deliverables:	5 AI Systems, 6 AI Risks, 10 AI Controls, 4 Policies
Date:	March 2026
Classification:	CONFIDENTIAL

1. EXECUTIVE SUMMARY

Mindful AI Labs is a 200-employee artificial intelligence company headquartered in Toronto, developing machine learning models for two high-stakes domains: healthcare diagnostics (medical imaging analysis, clinical decision support, drug interaction prediction) and financial risk scoring (credit decisioning, fraud detection, anti-money laundering). The company serves clients across Canada and the European Union, placing it under the jurisdiction of the EU AI Act (Regulation (EU) 2024/1689), Canada's proposed Artificial Intelligence and Data Act (AIDA), and existing regulations including GDPR, PIPEDA, and sector-specific healthcare and financial regulations. The EU AI Act classifies Mindful AI's healthcare diagnostic models as HIGH-RISK AI SYSTEMS under Annex III because they are medical devices and AI systems used for health-related purposes. Financial risk scoring models are also classified as high-risk because they are used for creditworthiness assessment and risk pricing affecting individuals' access to financial services. As AI Governance Lead, this project implements an AI Management System (AIMS) aligned with ISO/IEC 42001:2023, the world's first international standard for AI governance. The project inventories 5 AI systems with lifecycle tracking, assesses 6 AI-specific risks covering bias, transparency, safety, privacy, and accountability, implements 10 AI governance controls, and establishes 4 policies for responsible AI development and deployment.

2. AI SYSTEM INVENTORY - 5 AI SYSTEMS

Each system is inventoried with lifecycle tracking covering training data, performance, fairness metrics, and regulatory classification.

System 1: MedVision AI - Medical Imaging Diagnostic Model

FIELD	DETAILS
Name	MedVision AI - Medical Imaging Diagnostic Model
Type	Application
Classification	Critical
Owner	VP of Healthcare AI
Environment	Production
Description	Deep learning model (convolutional neural network) analyzing medical images including X-rays, CT scans, and MRIs to assist radiologists in detecting: lung nodules and early-stage lung cancer, breast masses and calcifications in mammography, brain hemorrhages and stroke in CT, and bone fractures in emergency X-rays. Deployed in 45 hospitals across Canada and 20 EU healthcare institutions. Processes approximately 15,000 medical images daily. Trained on a dataset of 2.8 million annotated medical images from 120 institutions across 15 countries. Model performance: 94.2% sensitivity (correctly identifies disease when present) and 96.8% specificity (correctly identifies healthy when disease is absent). Model outputs a probability score (0-100%) with highlighted regions of interest on the image. The radiologist makes the FINAL diagnostic decision; the model provides a 'second read' to flag potential findings the radiologist might miss. Classified as a Class IIa Medical Device under EU MDR (Medical Device Regulation) and as a Software as Medical Device (SaMD) under Health Canada regulations. Subject to EU AI Act HIGH-RISK classification under Annex III Section 5(a) as an AI system intended to be used as a safety component of a product covered by Union harmonisation legislation (medical devices).

System 2: CreditLens AI - Financial Credit Risk Scoring Model

FIELD	DETAILS
Name	CreditLens AI - Financial Credit Risk Scoring Model
Type	Application

Classification	Critical
Owner	VP of Financial AI
Environment	Production
Description	Machine learning model (gradient boosted decision tree ensemble) providing credit risk scores used by 12 Canadian banks and 8 EU financial institutions for: consumer credit decisioning (approve, deny, or conditionally approve credit applications), risk-based pricing (determining interest rates based on predicted default probability), portfolio risk monitoring (identifying accounts with increasing risk of default), and regulatory capital calculation under Basel III requirements. Processes approximately 50,000 credit decisions daily. Trained on 15 years of credit performance data (8.5 million credit accounts with outcome labels). Model inputs: 142 features including credit history, income, employment, debt ratios, and payment behavior. Model output: probability of default (PD) score from 0.00 to 1.00 with explanatory factors for each decision. Subject to EU AI Act HIGH-RISK classification under Annex III Section 5(b) as an AI system used to evaluate the creditworthiness of natural persons. Subject to ECOA (Equal Credit Opportunity Act) fair lending requirements in US (for future expansion), OSFI guidelines in Canada, and EBA (European Banking Authority) guidelines on IRB models in the EU.

System 3: FraudShield AI - Real-Time Transaction Fraud Detection

FIELD	DETAILS
Name	FraudShield AI - Real-Time Transaction Fraud Detection
Type	Application
Classification	High
Owner	VP of Financial AI
Environment	Production
Description	Real-time fraud detection model analyzing banking transactions as they occur to identify potentially fraudulent activity. Uses an ensemble of: anomaly detection (identifies transactions deviating from the customer's normal pattern), supervised classification (trained on 5 million labeled fraud/legitimate transaction pairs), and graph neural network (analyzes transaction networks to identify coordinated fraud rings). Deployed for 15 financial institutions monitoring approximately 2.3 million transactions daily. Response time: under 100 milliseconds per transaction

	(real-time decisioning required). Model performance: 89% fraud detection rate with 0.3% false positive rate. False positives result in legitimate transactions being declined, causing customer frustration. The model provides a fraud probability score with contributing factors. Transactions above the threshold are either blocked automatically (high confidence) or flagged for human review (medium confidence). Updated monthly with new fraud patterns.

System 4: AI Training Data Platform (Data Lake and Feature Store)

FIELD	DETAILS
Name	AI Training Data Platform (Data Lake and Feature Store)
Type	Data Store
Classification	Critical
Owner	Chief Data Officer
Environment	Production
Description	Centralized data platform storing and managing ALL training data, validation data, and feature engineering pipelines for all AI models. Contains: 2.8 million annotated medical images (X-ray, CT, MRI) from 120 institutions, 15 years of credit performance data (8.5 million accounts), 5 million labeled fraud/legitimate transaction pairs, feature engineering pipelines that transform raw data into model inputs, data versioning tracking every dataset used for every model version, demographic metadata enabling fairness analysis across protected groups, and data quality monitoring dashboards. Built on AWS S3 for storage, AWS Glue for ETL, and a custom feature store for real-time feature serving. Data governance includes lineage tracking (where every data point came from), consent tracking for healthcare data (IRB approvals, patient consent records), and access controls ensuring only authorized teams can access specific datasets. Data retention follows regulatory requirements: healthcare data per PIPEDA and provincial health information acts, financial data per OSFI and banking regulations.

System 5: AI Model Registry and Deployment Platform (MLOps)

FIELD	DETAILS
Name	AI Model Registry and Deployment Platform (MLOps)

Type	Application
Classification	High
Owner	Director of MLOps
Environment	Production
Description	MLflow-based model registry and deployment platform managing the complete AI lifecycle: model version control (every trained model version stored with metadata including training data reference, hyperparameters, and performance metrics), model comparison dashboards showing performance across versions and demographic groups, A/B testing framework for gradual model rollout (new model serves 5% of traffic initially, scaling to 100% after validation), model monitoring detecting performance degradation and data drift in production, automated fairness reporting generating bias metrics for every model version, deployment pipeline with human approval gates before production release, model rollback capability to instantly revert to the previous version if issues are detected, and audit trail logging every model change with who approved it and why. Integrated with the data platform for end-to-end lineage: from training data through model training, validation, deployment, and production monitoring.

3. AI RISK ASSESSMENT - 6 RISKS

AI risks are fundamentally different: bias, fairness, explainability, safety, privacy, and accountability.

Risk 1: Algorithmic Bias Causing Discriminatory Healthcare Diag

FIELD	DETAILS
Title	Algorithmic Bias Causing Discriminatory Healthcare Diagnostics Across Demographic Groups
Category	Application Security
Status	Open
Likelihood	3 - Possible
Impact	5 - Severe
Risk Score	15 (3 x 5) - CRITICAL
Owner	VP of Healthcare AI
Description	MedVision AI may perform differently across demographic groups if the training data is not sufficiently representative. Known examples in the AI industry: a 2019 study published in Science found that a widely-used healthcare algorithm exhibited racial bias, as Black patients were assigned lower risk scores than equally sick White patients because the algorithm used healthcare costs (a proxy for health) as the target variable, and Black patients historically had lower healthcare spending due to systemic inequities in access, NOT because they were healthier. MindfulAI risks include: medical imaging models trained predominantly on images from certain populations may miss conditions that present differently in other populations (e.g., skin conditions on dark skin, bone density variations across ethnicities), demographic imbalance in training data (if 70% of mammography images are from one demographic, the model is more accurate for that group), and the model's 94.2% sensitivity may NOT be uniform: it could be 96% for one group and 88% for another, creating a diagnostic disparity with life-threatening consequences. LIKELIHOOD is 3 because MindfulAI has specifically curated diverse training data (120 institutions, 15 countries), but hidden biases in labeling practices and population prevalence differences are difficult to fully eliminate. IMPACT is 5 because a biased diagnostic model could: miss cancers in underserved populations (life-threatening), violate the EU AI Act's non-discrimination requirements (regulatory penalty up to 7% of turnover), result in withdrawal of medical device certification, and cause devastating reputational damage.

Risk 2: Lack of AI Explainability Leading to Regulatory Non-Com

FIELD	DETAILS
Title	Lack of AI Explainability Leading to Regulatory Non-Compliance and Loss of Trust
Category	Compliance
Status	Open
Likelihood	4 - Likely
Impact	4 - Major
Risk Score	16 (4 x 4) - CRITICAL
Owner	AI Governance Lead
Description	Both the EU AI Act and financial regulations require AI systems to be EXPLAINABLE: users and affected individuals must be able to understand why an AI system made a particular decision. MedVision uses a deep convolutional neural network which is inherently a 'black box': it can identify cancer in an image but cannot easily explain WHY in human-understandable terms. CreditLens uses gradient boosted trees which are more interpretable but with 142 features, individual decision explanations are still complex. Regulatory requirements: EU AI Act Article 13 requires high-risk AI to be 'sufficiently transparent to enable deployers to interpret the system's output and use it appropriately.' EU AI Act Article 86 gives individuals the right to an explanation of AI decisions affecting them. Financial regulations require specific reasons when credit applications are denied (adverse action notices). Current state: MedVision provides heatmaps showing which image regions influenced the decision but no text explanation. CreditLens provides top 5 contributing features but not in consumer-friendly language. LIKELIHOOD is 4 because: regulatory enforcement of explainability is imminent (EU AI Act provisions taking effect 2025-2027), and financial regulators already audit model explainability. IMPACT is 4 because: inability to explain decisions blocks EU market access, violates financial regulations, and erodes trust with healthcare and financial clients.

Risk 3: AI Model Drift Causing Degraded Performance in Producti

FIELD	DETAILS

Title	AI Model Drift Causing Degraded Performance in Production Without Detection
Category	Availability
Status	Open
Likelihood	4 - Likely
Impact	4 - Major
Risk Score	16 (4 x 4) - CRITICAL
Owner	Director of MLOps
Description	AI models are trained on historical data and assume that future data will follow similar patterns. When the real world changes, the model's predictions degrade. This is called MODEL DRIFT. Types: DATA DRIFT (the input data distribution changes, e.g., a new imaging machine produces images with different characteristics), CONCEPT DRIFT (the relationship between inputs and outputs changes, e.g., new fraud techniques that do not match historical patterns), and PERFORMANCE DRIFT (the model's accuracy gradually decreases over time). MindfulAI risks: MedVision's medical imaging model was trained on images from specific scanner models. When a hospital upgrades to a new scanner, the image characteristics change and the model's accuracy may drop WITHOUT anyone knowing. CreditLens was trained on pre-pandemic credit data. Post-pandemic economic conditions changed default patterns, potentially making pre-pandemic training data non-representative. FraudShield must continuously adapt to new fraud techniques that emerge monthly. Current monitoring: basic accuracy metrics are tracked but demographic-specific performance drift is not systematically monitored. LIKELIHOOD is 4 because model drift is INEVITABLE (the world changes constantly). IMPACT is 4 because undetected drift means: the healthcare model makes less accurate diagnoses (patient safety risk), the credit model scores inaccurately (financial risk and fairness risk), and neither MindfulAI nor its clients KNOW about the degradation until harm occurs.

Risk 4: Training Data Privacy Violations Under GDPR and PIPEDA

FIELD	DETAILS
Title	Training Data Privacy Violations Under GDPR and PIPEDA
Category	Data Protection
Status	Open

Likelihood	3 - Possible
Impact	4 - Major
Risk Score	12 (3 x 4) - HIGH
Owner	Chief Data Officer
Description	MindfulAI's training data includes: 2.8 million medical images that are PERSONAL DATA under GDPR (they relate to identified or identifiable individuals' health conditions), credit performance data for 8.5 million individuals that is PERSONAL DATA including financial profiles, and transaction data that reveals spending patterns constituting PERSONAL DATA. Privacy risks: CONSENT: were the 2.8M medical images collected with consent for AI training specifically (not just for treatment)? IRB approvals may not cover commercial AI training. PURPOSE LIMITATION: credit data collected for lending decisions may not be lawfully used for training a commercial AI model without additional legal basis. CROSS-BORDER TRANSFERS: training data from EU institutions transferred to Canada for model training requires adequate safeguards under GDPR Chapter V. DATA MINIMIZATION: does the training data contain more personal information than necessary for model training? Can images be de-identified while maintaining diagnostic value? RIGHT TO ERASURE: if a patient requests deletion under GDPR Article 17, how do you remove their data from an already-trained model? The model has 'learned' from their data even after deletion. LIKELIHOOD is 3 because MindfulAI has data governance processes but the intersection of AI training and privacy law is legally unsettled. IMPACT is 4 because GDPR violations carry penalties up to EUR 20M or 4% of turnover, and loss of data access would cripple model development.

Risk 5: Insufficient Human Oversight Leading to Automated Decis

FIELD	DETAILS
Title	Insufficient Human Oversight Leading to Automated Decisions Without Accountability
Category	Human Error
Status	Open
Likelihood	3 - Possible
Impact	5 - Severe

Risk Score	15 (3 x 5) - CRITICAL
Owner	AI Governance Lead
Description	The EU AI Act Article 14 requires HIGH-RISK AI systems to have effective HUMAN OVERSIGHT. This means: humans must be able to UNDERSTAND the AI's outputs, OVERRIDE the AI's decisions when necessary, and INTERVENE or STOP the system when it malfunctions. Risks: AUTOMATION BIAS: radiologists who rely on MedVision may reduce their own scrutiny, trusting the AI even when it is wrong. Studies show that humans tend to defer to automated recommendations even when they have information suggesting the AI is incorrect. ALERT FATIGUE: if FraudShield flags too many false positives, fraud analysts start ignoring alerts, missing real fraud. SKILL DEGRADATION: if radiologists rely on AI for cancer detection for years, their own diagnostic skills may atrophy, making them unable to function effectively without the AI. ACCOUNTABILITY GAP: when the AI makes an error, who is responsible? The AI developer (MindfulAI), the healthcare institution that deployed it, or the radiologist who accepted the AI's recommendation? Current state: MedVision is designed as a 'second read' (advisory role) but there is no formal protocol ensuring radiologists actually perform their own assessment before seeing the AI's output. LIKELIHOOD is 3 because MindfulAI designed systems as advisory, but automation bias is a well-documented human factors phenomenon. IMPACT is 5 because lack of human oversight in healthcare means: missed cancers due to automation bias (patient harm), regulatory violation of EU AI Act Article 14 (fines up to 7% of turnover), and undefined liability when errors occur.

Risk 6: EU AI Act Non-Compliance Due to Incomplete Conformity A

FIELD	DETAILS
Title	EU AI Act Non-Compliance Due to Incomplete Conformity Assessment Documentation
Category	Compliance
Status	Open
Likelihood	4 - Likely
Impact	5 - Severe
Risk Score	20 (4 x 5) - CRITICAL
Owner	AI Governance Lead

Description	The EU AI Act requires CONFORMITY ASSESSMENT for high-risk AI systems before they can be placed on the EU market. For healthcare AI (medical devices), this involves THIRD-PARTY conformity assessment through an EU notified body. For credit scoring AI, SELF-ASSESSMENT is sufficient but must include comprehensive documentation per Article 11: technical documentation covering design, development methodology, training data, performance metrics, risk management, and human oversight; quality management system covering all AI lifecycle processes; EU declaration of conformity for each system; and CE marking. Current state: MindfulAI has technical documentation for model performance but NOT in the format required by the EU AI Act. Risk management documentation covers cybersecurity but NOT AI-specific risks (bias, fairness, transparency). No conformity assessment has been conducted. No EU authorized representative has been designated (required for non-EU providers). LIKELIHOOD is 4 because the EU AI Act provisions for high-risk AI are being phased in (2025-2027) and MindfulAI has significant gaps. IMPACT is 5 because non-compliance means: INABILITY TO SERVE EU CLIENTS (40% of revenue), penalties up to EUR 35M or 7% of turnover, and reputational damage as an AI governance company that cannot meet governance requirements.

4. AI GOVERNANCE CONTROLS - 10 CONTROLS

Controls address the full AI lifecycle: development, testing, deployment, monitoring, and retirement.

Control 1: AI Risk Assessment Framework with Bias and Fairness Tes

FIELD	DETAILS
Name	AI Risk Assessment Framework with Bias and Fairness Testing
Framework	ISO 42001
Reference	ISO 42001 6.1.2 (AI risk assessment) | NIST AI RMF MAP & MEASURE | EU AI Act Art. 9
Effectiveness	Effective
Frequency	Quarterly (per model) + triggered by model updates
Owner	AI Governance Lead (
Description	Formal AI risk assessment process applied to every model BEFORE deployment and QUARTERLY during production. Assessment covers 6 dimensions: BIAS AND FAIRNESS: statistical parity, equalized odds, and disparate impact ratio tested across protected groups (age, gender, ethnicity, disability). For MedVision: sensitivity and specificity calculated for each demographic group with maximum allowable disparity of 5 percentage points. For CreditLens: approval rate ratios across demographic groups must be within ECOA adverse impact thresholds. SAFETY: failure mode analysis identifying what happens when the model is wrong and mitigations for each failure mode. TRANSPARENCY: explainability assessment using model-appropriate techniques (Grad-CAM for imaging, SHAP values for credit scoring). PRIVACY: data protection impact assessment for training data. SECURITY: adversarial robustness testing (can the model be fooled by manipulated inputs?). ACCOUNTABILITY: clear definition of who is responsible for the model's outputs and who has authority to override or stop it.

Control 2: Algorithmic Fairness Testing with Demographic Parity Mo

FIELD	DETAILS
Name	Algorithmic Fairness Testing with Demographic Parity Monitoring
Framework	ISO 42001

Reference	ISO 42001 6.1.4 (AI system impact assessment) | NIST AI RMF MEASURE 2.6-2.11 | EU AI Act Art. 10
Effectiveness	Effective
Frequency	Continuous (production monitoring) + Quarterly (comprehensive audit)
Owner	VP of Healthcare AI + VP of Financial AI
Description	Automated fairness testing pipeline that evaluates every model version against multiple fairness metrics BEFORE deployment and CONTINUOUSLY in production. Metrics: STATISTICAL PARITY: the model's positive outcome rate should be similar across protected groups. EQUALIZED ODDS: the model's error rates (false positives and false negatives) should be similar across groups. DISPARATE IMPACT RATIO: the ratio of positive outcome rates between groups must exceed 0.8 (the four-fifths rule used in US employment discrimination law, applied here as a fairness benchmark). CALIBRATION: the model's predicted probabilities should be equally accurate across groups. For MedVision: weekly fairness dashboards showing sensitivity and specificity BY demographic group. If any group's sensitivity drops below 90% (while the overall average is 94.2%), an ALERT triggers investigation. For CreditLens: monthly fair lending reports showing approval rates, pricing, and adverse action rates by protected group. Reports reviewed by the Fair Lending Committee before submission to banking regulators.

Control 3: AI Explainability and Transparency Framework

FIELD	DETAILS
Name	AI Explainability and Transparency Framework
Framework	ISO 42001
Reference	ISO 42001 Annex B (AI transparency) | NIST AI RMF GOVERN 1.7 | EU AI Act Art. 13
Effectiveness	Effective
Frequency	Continuous (per decision) + Quarterly (review)
Owner	Director of MLOps
Description	Layered explainability providing appropriate detail for each audience. TECHNICAL LAYER (for data scientists and auditors): full model architecture documentation, training data description, hyperparameters, feature importance rankings, and SHAP/LIME explanations for individual predictions. DEPLOYER

	LAYER (for hospitals and banks using the system): model capability statements, known limitations, performance metrics including fairness breakdowns, recommended use cases, and contraindications. USER LAYER (for radiologists and loan officers): clear presentation of model confidence, highlighted decision factors, and explicit statement that the model is advisory (human makes final decision). AFFECTED INDIVIDUAL LAYER (for patients and credit applicants): plain-language explanation of what the AI system does, how it affects them, and their right to human review. For MedVision: Grad-CAM heatmaps showing which image regions influenced the decision, plus a text explanation like 'the model detected a 23mm opacity in the right upper lobe with characteristics consistent with a pulmonary nodule (confidence: 87%). Radiologist review is required.' For CreditLens: adverse action notices listing the top 4 factors that negatively affected the score in consumer-friendly language.

Control 4: Human Oversight Protocol with Blind-First-Read for Heal

FIELD	DETAILS
Name	Human Oversight Protocol with Blind-First-Read for Healthcare AI
Framework	ISO 42001
Reference	ISO 42001 Annex C (Human oversight) | EU AI Act Art. 14 | NIST AI RMF GOVERN 1.3
Effectiveness	Effective
Frequency	Continuous (every AI-assisted decision)
Owner	VP of Healthcare AI
Description	Formal human oversight mechanisms ensuring AI remains ADVISORY and humans retain decision authority. For MedVision: BLIND FIRST READ protocol where the radiologist performs their own assessment of the medical image BEFORE seeing MedVision's output. Only after the radiologist has documented their preliminary findings does the AI output become visible, allowing comparison. This prevents AUTOMATION BIAS (the radiologist anchoring on the AI's recommendation). If the radiologist and AI disagree, a structured reconciliation process requires the radiologist to document WHY they accepted or overrode the AI. For CreditLens: loan officers review the AI score alongside traditional underwriting factors. The AI score CANNOT automatically approve or deny a loan; a human must make the final decision for all applications above $50,000 and for all applications where the AI recommends denial. For FraudShield: high-confidence fraud scores (above 95%) trigger automatic blocking. Medium-confidence (70-95%) are queued for human review within 30 minutes. All blocked

	transactions include a customer notification with a one-click 'this was me' override.

Control 5: Training Data Governance with Representativeness and Co

FIELD	DETAILS
Name	Training Data Governance with Representativeness and Consent Management
Framework	ISO 42001
Reference	ISO 42001 Annex A.2 (Data for AI systems) | EU AI Act Art. 10 | NIST AI RMF MAP 2.1-2.3
Effectiveness	Effective
Frequency	Continuous (data ingestion) + Annual (comprehensive data audit)
Owner	Chief Data Officer
Description	Comprehensive data governance for all AI training data covering: REPRESENTATIVENESS: every training dataset is profiled for demographic representation. Targets: no single demographic group should constitute more than 60% of any training dataset, and underrepresented groups should have sufficient samples for statistically reliable performance measurement (minimum 500 samples per subgroup). CONSENT: medical imaging data tracked by consent type (IRB research approval, explicit patient consent for AI, anonymized data). All data sources documented with legal basis for processing. BIAS EXAMINATION: automated bias detection in training data comparing distributions of outcomes across protected groups. If training data shows historical bias (e.g., fewer credit approvals for certain demographics), this is documented and the model training process includes de-biasing techniques. DATA LINEAGE: every training example traceable to its source institution, collection date, consent status, and any transformations applied. DATA QUALITY: automated checks for: label accuracy (sample of medical image labels reviewed by two independent radiologists), feature completeness, outlier detection, and temporal consistency. GDPR COMPLIANCE: Data Protection Impact Assessment for all AI training datasets, Article 30 records for training data processing, and documented legal basis (typically legitimate interest for model improvement with balancing test).

Control 6: AI Model Lifecycle Management with Version Control and

FIELD	DETAILS

Name	AI Model Lifecycle Management with Version Control and Rollback
Framework	ISO 42001
Reference	ISO 42001 8.4 (AI system lifecycle) | EU AI Act Art. 9(2) | NIST AI RMF MANAGE 3.1-3.2
Effectiveness	Effective
Frequency	Continuous
Owner	Director of MLOps
Description	Complete AI lifecycle management through the MLOps platform covering: DEVELOPMENT: model training in isolated environments with reproducible pipelines (same data + same code = same model). All experiments tracked in MLflow with hyperparameters, metrics, and data references. VALIDATION: multi-stage testing before deployment including: accuracy testing on held-out data, fairness testing across all protected groups, adversarial robustness testing (can the model be fooled?), performance testing under load, and regression testing (new model does not degrade on cases the old model handled correctly). DEPLOYMENT: staged rollout via A/B testing (5% traffic initially, scaling to 100% after 2-week validation). Human approval gate required before production deployment. MONITORING: continuous tracking of accuracy, fairness, latency, and data drift in production with automated alerting when metrics exceed thresholds. RETIREMENT: formal process for decommissioning models including: notification to all deployers, transition plan, data retention decisions, and documentation archival. Every model version is retained with full reproducibility for 7 years (regulatory retention requirement).

Control 7: Continuous AI Model Monitoring with Drift Detection and

FIELD	DETAILS
Name	Continuous AI Model Monitoring with Drift Detection and Alerting
Framework	ISO 42001
Reference	ISO 42001 9.1 (Monitoring and measurement) | EU AI Act Art. 61 (Post-market monitoring) | NIST AI RMF MANAGE 4.1
Effectiveness	Effective
Frequency	Continuous
Owner	Director of MLOps

Description	Real-time monitoring of all production AI models detecting: DATA DRIFT: statistical tests (KS test, PSI) comparing current input data distribution against training data distribution. Alert when drift exceeds threshold indicating the model may be operating on data significantly different from what it was trained on. PERFORMANCE DRIFT: continuous accuracy metrics compared against baseline. For MedVision: sensitivity and specificity tracked daily. For CreditLens: prediction accuracy (Gini coefficient, KS statistic) tracked monthly against validation set. FAIRNESS DRIFT: demographic-specific performance metrics tracked continuously. Alert if any subgroup's performance degrades faster than overall performance. CONCEPT DRIFT: monitoring for changes in the relationship between inputs and outputs. For FraudShield: emerging fraud patterns that do not match historical training trigger retraining. Dashboard showing all models' health status: GREEN (within thresholds), YELLOW (approaching thresholds), RED (exceeding thresholds requiring immediate investigation). Red alerts trigger the incident response process and potential model rollback.

Control 8: Adversarial Robustness Testing for AI Models

FIELD	DETAILS
Name	Adversarial Robustness Testing for AI Models
Framework	NIST CSF
Reference	ISO 42001 Annex B.4 (AI security) | NIST AI RMF MEASURE 2.6 | EU AI Act Art. 15 (Accuracy, Robustness, Cybersecurity)
Effectiveness	Effective
Frequency	Quarterly + before each model deployment
Owner	AI Security Lead
Description	Testing AI models against adversarial attacks designed to cause incorrect outputs. Attack types tested: EVASION ATTACKS: manipulating inputs to cause misclassification. For MedVision: testing whether small pixel modifications to medical images can cause the model to miss a tumor or falsely detect one. For CreditLens: testing whether applicants can manipulate features to artificially improve their score. DATA POISONING: testing resilience to corrupted training data. Verifying that the model training pipeline detects and rejects anomalous training examples. MODEL EXTRACTION: testing whether the model's behavior can be replicated by querying it extensively, potentially enabling a competitor to steal the model. PROMPT INJECTION (for any LLM components): testing whether adversarial prompts can cause the system to produce harmful outputs

	or leak training data. Testing methodology: red team exercises using established frameworks (IBM ART, Microsoft Counterfit) to generate adversarial examples. Results documented with severity ratings and remediations.

Control 9: AI Incident Response and Model Rollback Procedure

FIELD	DETAILS
Name	AI Incident Response and Model Rollback Procedure
Framework	ISO 42001
Reference	ISO 42001 Annex A.7 (AI incident management) | NIST AI RMF MANAGE 4.2 | EU AI Act Art. 62
Effectiveness	Effective
Frequency	Triggered by incidents + Quarterly tabletop exercises
Owner	AI Governance Lead
Description	AI-specific incident response plan covering scenarios unique to AI systems: PERFORMANCE DEGRADATION: model accuracy drops below acceptable threshold. Immediate actions: alert model owner, investigate root cause (data drift, concept drift, or system issue), activate fallback procedure (for MedVision: disable AI overlay, radiologists continue with standard reading), and if necessary, rollback to the previous model version. BIAS INCIDENT: fairness monitoring detects significant performance disparity across demographic groups. Immediate actions: pause model for affected subgroup, investigate root cause, implement corrective action (additional training data, model retraining, or feature modification), and file regulatory notification if required (EU AI Act Article 62 requires serious incident reporting to market surveillance authorities). ADVERSARIAL ATTACK: evidence that someone is manipulating model inputs. Immediate actions: block suspicious inputs, preserve evidence, investigate scope, and implement input validation rules. The EU AI Act Article 62 requires providers to report SERIOUS INCIDENTS (incidents leading to death, serious health damage, disruption of critical infrastructure, or serious violation of fundamental rights) to the market surveillance authority IMMEDIATELY.

Control 10: EU AI Act Conformity Assessment Preparation and Documen

FIELD	DETAILS
Name	EU AI Act Conformity Assessment Preparation and Documentation

Framework	ISO 42001
Reference	ISO 42001 10.1 (Improvement) | EU AI Act Art. 43 (Conformity assessment) | EU AI Act Art. 11 (Technical documentation)
Effectiveness	Partially Effective
Frequency	Annual (full assessment) + Continuous (documentation updates)
Owner	AI Governance Lead (
Description	Preparing MindfulAI for EU AI Act conformity assessment by compiling all required documentation: TECHNICAL DOCUMENTATION per Article 11 and Annex IV: general description of the AI system, design specifications and development methodology, training data description with representativeness analysis, performance metrics including fairness testing results, risk management documentation, human oversight mechanisms, and cybersecurity measures. QUALITY MANAGEMENT SYSTEM per Article 17: policies and procedures for all AI lifecycle activities, data management procedures, risk management procedures, post-market monitoring procedures, and incident reporting procedures. EU DECLARATION OF CONFORMITY per Article 47: formal declaration that each high-risk AI system meets EU AI Act requirements. EU AUTHORIZED REPRESENTATIVE per Article 22: designation of an EU-based entity to act as MindfulAI's representative for regulatory purposes. RATED PARTIALLY EFFECTIVE because: technical documentation is 70% complete, quality management system is operational but not fully documented to EU AI Act standards, no conformity assessment has been conducted yet, and no EU authorized representative has been designated. Full compliance targeted by Q4 2026 aligned with EU AI Act implementation timeline.

5. POLICY LIBRARY - 4 AI GOVERNANCE POLICIES

These 4 policies establish the governance framework for responsible AI development and deployment.

Policy 1: Responsible AI Development and Deployment Policy

FIELD	DETAILS
Title	Responsible AI Development and Deployment Policy
Status	Approved
Owner	CEO
Review Date	September 30, 2026
Description	The foundational AI governance policy establishing MindfulAI's principles for responsible AI. Core provisions: (1) HUMAN-CENTERED AI: all AI systems must be designed to augment human decision-making, not replace it. Humans retain final authority over consequential decisions in healthcare and finance. (2) FAIRNESS AND NON-DISCRIMINATION: AI systems must be tested for bias across protected characteristics before deployment and monitored continuously. Performance disparities exceeding defined thresholds trigger mandatory investigation and remediation. (3) TRANSPARENCY: AI decision-making must be explainable to all stakeholders at an appropriate level of detail. No 'black box' decisions affecting individuals are permitted without human review. (4) SAFETY: AI systems must undergo risk assessment before deployment. Healthcare AI systems require clinical validation. Financial AI systems require model validation. (5) PRIVACY: AI training and operation must comply with GDPR, PIPEDA, and applicable data protection laws. Training data governance must ensure consent, purpose limitation, and data minimization. (6) ACCOUNTABILITY: every AI system has a designated model owner, a human oversight authority, and a documented escalation path for concerns. (7) CONTINUOUS IMPROVEMENT: AI systems are monitored throughout their lifecycle with regular reassessment of risks and performance.

Policy 2: AI Fairness and Bias Mitigation Policy

FIELD	DETAILS
Title	AI Fairness and Bias Mitigation Policy
Status	Approved

Owner	AI Governance Lead
Review Date	September 30, 2026
Description	Detailed policy governing how MindfulAI identifies, measures, mitigates, and monitors algorithmic bias across all AI systems. Key provisions: (1) PROTECTED CHARACTERISTICS: age, gender, race/ethnicity, disability, religion, sexual orientation, and socioeconomic status. Models must not discriminate directly or indirectly based on these characteristics. (2) FAIRNESS METRICS: each AI system must define appropriate fairness metrics before development. Healthcare: equal sensitivity and specificity across demographic groups. Finance: equal approval rates controlling for creditworthiness (disparate impact analysis). (3) TESTING REQUIREMENTS: fairness testing is MANDATORY before deployment. No model can be released to production without a fairness report reviewed and approved by the AI Ethics Committee. (4) PROXY VARIABLE ANALYSIS: features that may serve as proxies for protected characteristics (e.g., postal code as proxy for ethnicity) must be identified and assessed. (5) TRAINING DATA DIVERSITY: minimum representativeness requirements for training datasets. (6) ONGOING MONITORING: production fairness metrics tracked continuously with automated alerting. (7) REMEDIATION: when bias is detected, the model is flagged for investigation. If bias is confirmed, remediation options include: additional training data, feature modification, model architecture changes, or in extreme cases, model withdrawal from production.

Policy 3: AI Data Governance and Privacy Policy

FIELD	DETAILS
Title	AI Data Governance and Privacy Policy
Status	Approved
Owner	Chief Data Officer
Review Date	September 30, 2026
Description	Governs how MindfulAI collects, stores, uses, and protects data used for AI training and operation. Key provisions: (1) LEGAL BASIS: every training dataset must have a documented legal basis for processing under GDPR and PIPEDA. Health data requires explicit consent or research exemption. Financial data requires contractual basis or legitimate interest with balancing test. (2) DATA MINIMIZATION: training data must be limited to what is necessary. Identifiable data must be de-identified or anonymized where possible without compromising model quality. (3) CONSENT MANAGEMENT: all medical imaging data tracked

	by consent type. Data collected under one consent scope cannot be used for different purposes without additional consent or legal basis. (4) CROSS-BORDER TRANSFERS: data transfers between Canada and EU comply with GDPR Chapter V using Standard Contractual Clauses. Data localization requirements respected for jurisdictions that mandate local processing. (5) RETENTION: training data retained only as long as necessary for model maintenance and regulatory requirements. Retention periods defined per data type and regulatory requirement. (6) RIGHT TO ERASURE: process for handling deletion requests including assessment of impact on trained models and documentation of machine unlearning techniques where applicable. (7) DATA BREACH: specific procedures for AI training data breaches including assessment of whether model outputs may be affected.

Policy 4: AI Incident Response and Escalation Policy

FIELD	DETAILS
Title	AI Incident Response and Escalation Policy
Status	Approved
Owner	AI Governance Lead
Review Date	September 30, 2026
Description	Governs how MindfulAI responds to AI-specific incidents including: (1) PERFORMANCE INCIDENTS: model accuracy or fairness metrics breach defined thresholds. Severity levels: P1 (healthcare model safety metric breached, potential patient harm), P2 (financial model fairness metric breached, potential discrimination), P3 (performance degradation without immediate safety impact), P4 (minor metric fluctuation within acceptable range). (2) BIAS INCIDENTS: evidence of systematic discrimination in model outputs. Mandatory investigation, potential model suspension, and regulatory notification if the bias constitutes a serious incident under EU AI Act Article 62. (3) SAFETY INCIDENTS: any event where an AI system contributed to harm or near-harm. For MedVision: missed diagnosis leading to delayed treatment. For CreditLens: systematic unfair denial of credit to a protected group. IMMEDIATE reporting to the AI Ethics Committee and regulatory notification within 15 days per EU AI Act Article 62. (4) ADVERSARIAL INCIDENTS: evidence of deliberate manipulation of AI systems. Forensic investigation, model hardening, and potential law enforcement notification. (5) REGULATORY INCIDENTS: notices from regulators regarding AI compliance. Immediate escalation to Legal and CEO. Each incident type has: defined severity levels, escalation paths, response timelines, communication templates, and post-incident review requirements.

6. AI GOVERNANCE PROGRAM SUMMARY

Component	Details	Status
AI Systems	5 inventoried with lifecycle tracking	**Complete**
AI Risks	6 assessed (3 Critical, 2 High, 1 Critical)	Documented
AI Controls	10 implemented (9 Effective, 1 Partially Effective)	**Operational**
Policies	4 approved (Responsible AI, Fairness, Data Gov, Incident)	**Approved**
EU AI Act	Conformity assessment prep 70% complete	In Progress
ISO 42001	AIMS implemented, certification targeted Q1 2027	In Progress